

CIRO

Technical Architecture

System design, API surface, database schema, deployment topology, and security controls

Author	Saqib Azair
Document No.	CIRO-DOC-002
Version	3.0
Date	September 01, 2026
Project	Alibaba Cloud x Bano Qabil Hackathon 2026
Status	Final Submission

This document describes the full technical architecture of CIRO v3.0. It covers the layered backend structure, the 10-agent AI pipeline internals, the complete API surface (82 endpoints), the database schema (18 tables across 10 migrations), the WebSocket realtime system, and the deployment topology on Netlify, Railway, and Alibaba Cloud.

Website	https://ciroquick.netlify.app
API Backend	https://bano-qabil-alibabacloud-hackthon-ciro-app-production.up.railway.app
Repository	https://github.com/saqib54/Bano-Qabil-AlibabaCloud-Hackthon-CIRO-APP

This document is part of the CIRO official documentation suite prepared for the Alibaba Cloud x Bano Qabil Hackathon. All content is based on the implemented system.

01

Technology Stack

Every layer: language, framework, library, and rationale

Layer	Technology	Version	Role / Rationale
Frontend Framework	React	18	Component-based SPA with concurrent rendering; hooks-first
Build Tool	Vite	5	Sub-second HMR; optimised rollup production builds
CSS	Tailwind CSS	3	Utility-first; design tokens in tailwind.config.js
State — Client	Zustand	latest	Minimal global store (auth, theme, language)
State — Server	TanStack Query	latest	Server-state cache, background refetch, optimistic updates
Maps	Leaflet / react-leaflet	latest	Free OpenStreetMap tiles; Google Maps key for geocoding
HTTP Client	Axios	latest	Interceptors for JWT attach and 401 refresh retry
Backend Runtime	Node.js	20 LTS	Long-term support; single-language full stack
Backend Framework	Express	4	Minimal, extensible; 82 endpoints across 11 route files
Database	SQLite (better-sqlite3)	3	Zero-ops; synchronous API; WAL mode; file-portable
Realtime	ws (WebSocket)	latest	Sub-second fan-out; role-scoped broadcast registry
Auth — Tokens	jsonwebtoken	latest	Access 15 min / refresh 7 days; RS256 for Firebase verify
Auth — Hashing	bcryptjs	latest	Password and OTP code hashing at rest
Auth — Social	Firebase Admin	latest	ID token verification via Google securetoken x509 certs
AI — Text	Qwen (DashScope) / fallback	qwen-plus	JSON-mode inference; deterministic fallback always available
AI — Vision	qwen-vl-plus / fallback	latest	Image analysis; heuristic fallback
Mobile	Capacitor	8	One web codebase -> Android APK + iOS; native plugin bridge
File Uploads	multer	latest	Multipart handler; OSS adapter ready
Hosting — Web	Netlify	—	Git-push auto-deploy; CDN; base dir = client/
Hosting — API	Railway	—	nixpacks auto-build; Node 20; git-push deploy
Cloud — Target	Alibaba Cloud ECS	—	pm2 + nginx; DirectMail (OTP); OSS (uploads); ApsaraDB RDS

02

System Architecture

Three-tier client-server architecture with realtime WebSocket layer

CIRO follows a three-tier architecture. Thin clients (React SPA and Capacitor mobile apps) communicate with the Express API over HTTPS REST for commands and queries, and via WebSocket for real-time push events. The API orchestrates SQLite storage, the deterministic AI pipeline, Firebase auth verification, and optional external services.

Tier	Component	Host / Technology	Connects To
CLIENT	React SPA (Web Portal)	Netlify CDN	API: HTTPS REST + WSS
CLIENT	Android APK	Capacitor 8 / Local Build	API: HTTPS REST + WSS
CLIENT	iOS App	Capacitor 8 / Xcode	API: HTTPS REST
API	Express REST API (/api/v1)	Railway (Node 20, :8080)	SQLite, AI Pipeline, Auth, Uploads
API	WebSocket Hub	Same Railway process	All connected clients — role-scoped
API	AI Triage Pipeline	In-process (aiPipeline.service.js)	SQLite (reads + writes verdict)
API	Auth Service	In-process (auth.service.js)	Firebase x509 certs, JWT, bcrypt
DATA	SQLite Database	Railway volume / ECS disk	Express services
DATA	Incident Media Uploads	server/uploads/ (OSS-ready)	multer -> storage.service
EXTERNAL	Firebase Auth	Google Cloud	Token verification (x509 RS256)
EXTERNAL	Point Forecast API	Open-Meteo / Qwen	Weather endpoint
EXTERNAL	Qwen (DashScope)	Alibaba Cloud	AI inference (optional)
EXTERNAL	SMTP Provider	Resend / DirectMail	OTP email delivery (optional)

03

Backend Layered Structure

Strict layer separation: routes -> controllers -> services -> repositories -> SQLite

The backend enforces strict layer separation. Controllers never write SQL. Repositories own all prepared statements. Services own business logic. This ensures testability, replaceability, and clear audit boundaries.

Directory / File	Contents & Responsibility
routes/ (11 files)	auth.routes, incidents.routes, ai.routes, admin.routes, staff.routes, map.routes, notifications.routes, ...
controllers/	HTTP layer: parse req, call service, wrap in {success, message, data} envelope, send response. C...
services/	Business logic: auth.service (JWT, OTP, Google verify), incident.service (lifecycle, status), aiPipel...
repositories/	Data access: all SQLite queries as prepared statements. Repositories are the only layer that touch...
middleware/	authenticate (JWT verify, attach req.user), requireRole (RBAC gate), validate (express-validator sc...

Directory / File	Contents & Responsibility
validators/	Request schema validators using express-validator for all POST/PATCH routes. Centralised validation logic.
websocket/	Connection registry with sendToUser(userId, event, data), broadcastToRole(role, event, data), broadcastToAll(event, data).
config/	Environment variable loading (dotenv), JWT configuration, database path resolution, CORS allowlist.
database/migrations/	10 SQL migration files (001-010); applied in order on cold start via schema_migrations bookkeeping.
database/seeds/	seed.js: conditional seed (only runs if users = 0) — creates demo accounts (citizen, responder, admin).

INFO Response Envelope — every single API endpoint returns: { "success": true/false, "message": "...", "data": { ... } } Errors use ApiError with HTTP status codes and human-readable messages.

04

Complete API Surface — 82 Endpoints

All routes grouped by module with access control and key highlights

Module	Count	Access	Key Endpoints
auth	8	Public+	POST /register, /login, /google, /otp/request, /otp/verify, /refresh, /logout; GET
incidents	6	PUBLIC+	POST / (multipart); GET /mine, /, /:id, /:id/verification; PATCH /:id/cancel
ai	1	PUBLIC	POST /ai/extract — stateless NLU: category, location, people, severity, teams
admin — kpis	2	ADMIN	GET /kpis, /verification-feed
admin — incidents	8	ADMIN	GET /incidents, /:id; PATCH /:id/verify, /:id/assign; POST /:id/approve-dispatch
admin — resolutions	3	ADMIN	GET /resolutions/:id; PATCH /:id/approve, /:id/reject, /:id/reopen
admin — staff	3	ADMIN	POST /staff; GET /staff, /staff/detailed; PATCH /staff/:id
admin — departments	3	ADMIN	GET/POST /departments; PATCH /departments/:id, /:id/toggle
admin — broadcasts	2	ADMIN	GET/POST /broadcasts; PATCH /:id/deactivate
admin — dispatch	2	ADMIN	GET /dispatch/recommendations; POST /dispatch/auto-assign
admin — misc	4	ADMIN	GET /analytics, /resources, /weather, /audit, /settings; PATCH /settings
staff	8	STAFF	GET /kpi; PATCH /duty-status; GET/PATCH /assignments, /:id/accept, /:id/sta
map & shelters	6	Mixed	GET /map/incidents, /map/responders; GET/POST /shelters; PATCH /shelters
notifications	4	Authenticated	GET /; PATCH /mark-all-read, /:id/read; GET /alerts
users/profile	2	Authenticated	GET /users (ADMIN); GET/PATCH /profile
weather	1	Authenticated	GET /weather?city= — full AI meteorologist briefing
assistant	1	Authenticated	POST /assistant/chat — safety Q&A with approved templates
system	1	Public	GET /health
TOTAL	82		

05

Database Schema — 18 Tables, 10 Migrations

SQLite with WAL mode; auto-migrate + conditional seed on every cold start

The schema is managed by 10 sequential SQL migration files. On cold start, the server applies any unapplied migrations and conditionally seeds demo data if the users table is empty. This makes CIRO boot-ready on any host with zero manual setup.

Table	Key Columns	Purpose
users	id (UUID), full_name, email, role, provider, provider_sub, avatar_url, is_responder, admin	Auth, roles, accounts, citizens, responders
otp_codes	id, email, code_hash, expires_at, attempts, reserved	Reserve for email OTP; bcrypt-hashed, single-use
refresh_tokens	id, user_id, token_hash, expires_at, revoked	JWT refresh token store with reuse detection
departments	id, name, code, description, contact, is_active	Emergency response departments (Fire, Rescue 1122, Police)
staff_profiles	user_id, department_id, designation, duty_status, order_id, cancel_eta	Responder role, cancellation, ETA for SmartDispatch
incidents	id, incident_number, reported_by, category, status, severity, details, full_location, metadata, ai_suggestion	Core incident data, status, severity, details, full location, metadata, ai suggestion
incident_media	id, incident_id, file_url, mime_type, size_bytes	Photos and evidence files per incident
incident_status_history	id, incident_id, previous_status, new_status, changed_by, note	Full history of every state transition logged
incident_situation_logs	id, incident_id, staff_id, note, image_url	Field responder update notes with optional photos
incident_ai_analysis	incident_id, ai_summary, recommended_severity, confidence, analysis	AI analysis (retained alongside pipeline)
incident_verification	id, incident_id, verdict, confidence, severity, flags	Flag for more pipeline flags, satellite signals, targeted ops
forecast_hotspots	id, category, latitude, longitude, radius_m, computed_historical_score, window_days	Computer historical score, window days and center forecast
notifications	id, user_id, type, title, message, severity, is_read, created_at	Push, email, in-app; WebSocket + persistent store
emergency_broadcasts	id, title, message, severity, target_audience, region_id, created_at, expires_at, auto_verify	Any range (US/CA) created; byte-exposed; AUTO_VERIFY
shelters	id, name, type, address, latitude, longitude, safety_level, is_active	Safety level, registry shown on citizen safety map
emergency_contacts	id, name, number, category, region, is_active	Seeded helplines: Rescue 1122, Police 15, Fire 16
audit_logs	id, actor_id, action, entity, entity_id, previous_value, new_value, created_at	Sample event trail, one per JSON-logged action
schema_migrations	applied_file (PK)	Migration bookkeeping — prevents duplicate application

06

WebSocket Realtime System

Sub-second role-scoped event fan-out via ws library

Event	Emitted When	Recipients
incident.new	New incident submitted	ADMIN, STAFF
incident.update	Status change, verdict, ETA, team assigned	Reporter (citizen), ADMIN

Event	Emitted When	Recipients
incident.dispatched	Dispatch approved	STAFF in assigned department
alert.broadcast	Emergency broadcast created / auto-alert	All connected clients
notification.new	Any notification inserted	Target user only
staff.assignment	Assignment pushed to responder	Target STAFF user
incident.pipeline	AI pipeline stage completed	ADMIN (trace view)

Registry helpers: `sendToUser(userId, event, data)` | `broadcastToRole(role, event, data)` | `broadcastToAll(event, data)`. JWT is verified on WebSocket upgrade; a 4401 close code is sent on token expiry.

07 Security & Safety Controls

Control	Implementation
RBAC	Role middleware on every route; three roles (PUBLIC/STAFF/ADMIN); citizens see only their own
JWT Rotation	Access token 15 min; refresh 7 days with rotation; reuse of a consumed refresh token triggers fami
Firebase Verification	Local RS256 verification against Google securetoken x509 certs (1-hour in-memory cache); NOT th
Rate Limiting	Global rate limiter on all endpoints; dedicated OTP limiter (10 requests / 15 minutes); login endpoint
OTP Hardening	6-digit code bcrypt-hashed at rest; 10-minute expiry; 5 attempt limit with lock; 30-second request co
Password Security	bcrypt with configured salt rounds; passwords never stored in plaintext; password confirmation vali
Input Sanitization	express-validator schema on all POST/PATCH routes; 1 MB JSON body cap (express limit); multie
Security Headers	helmet middleware with custom security headers; CORS allowlist (comma-separated FRONTEND_
Medical Privacy	Medical impact zones are private by design: impact_shape.kind = 'private', affected_estimate store
AI Governance	Human approval mandatory for dispatch; authority-approved templates only for citizen-facing AI rep
Audit Trail	audit_logs table captures every privileged action: actor_id, action type, entity, previous and new va

08 Deployment Topology & Environment

Current: Netlify + Railway. Target: Alibaba Cloud ECS + OSS + DirectMail

Component	Current Host	Auto-Deploy	Alibaba Cloud Equivalent
Web SPA	Netlify (base dir: client/)	GitHub push -> main branch	Alibaba Cloud CDN + OSS static
REST API	Railway (root dir: server/, Node 20)	GitHub push -> main branch	ECS + pm2 + nginx reverse proxy
Database	SQLite file on Railway volume	Auto-migrate on boot	ApsaraDB RDS (MySQL/PG) with adapter
Uploads	server/uploads/ on Railway	uses local storage	Alibaba OSS (adapter-ready, OSS_* env)
OTP Email	Demo: on-screen code	N/A	Alibaba DirectMail (SMTP drop-in)
AI Inference	Deterministic fallback	N/A	DashScope Qwen (DASHSCOPE_API_KEY)
Android APK	Local Gradle build	Manual: gradlew assembleDebug	Distribute via Play Store or direct APK
iOS App	Xcode local build	Manual: xcodebuild	App Store submission

KEY POINT Zero-Rebuild API Switching: client/public/runtime-config.json is loaded before app boot and overrides the compiled API URL. Moving from Railway to Alibaba Cloud ECS requires only a config file change — no frontend rebuild needed.

Variable	Purpose
PORT	API port (Railway injects; default 5000)
JWT_SECRET	HMAC secret for access token signing
JWT_REFRESH_SECRET	Separate secret for refresh token signing
JWT_ACCESS_EXPIRES_IN	Access token lifetime (e.g. 15m)
JWT_REFRESH_EXPIRES_IN	Refresh token lifetime (e.g. 7d)
FRONTEND_URL	Comma-separated CORS allowlist (all Vite ports, Netlify URL, Capacitor origins)
DATABASE_PATH	Path to SQLite file (default: server/database/ciro.sqlite)
FIREBASE_PROJECT_ID	Firebase project for ID token audience validation
DASHSCOPE_API_KEY	Alibaba DashScope key for Qwen inference (deterministic fallback if absent)
QWEN_TEXT_MODEL	Qwen text model name (default: qwen-plus)
QWEN_VL_MODEL	Qwen vision model name (default: qwen-vl-plus)
GOOGLE_MAPS_API_KEY	For geocoding non-builtin city names in weather endpoint
SMTP_HOST/PORT/USER/PASS	Nodemailer OTP email delivery; absent = demo code on screen
OSS_* (7 vars)	Alibaba OSS adapter for media uploads (optional; local disk default)